Analisi di Vulnerabilità e Penetration Testing su DVWA

1. Obiettivo del Progetto

L'attività ha avuto come scopo la simulazione di un attacco informatico per identificare e sfruttare una vulnerabilità di **File Upload**. L'analisi è stata condotta integrando concetti di ricognizione, intercettazione e controllo remoto in un ambiente controllato.

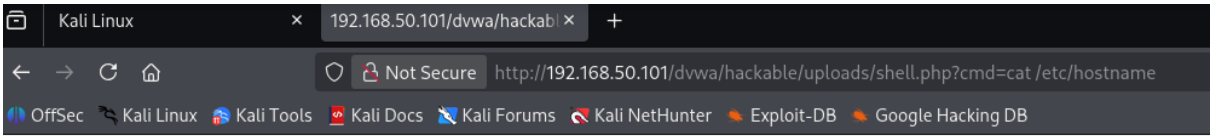
---

2. Analisi delle Fasi Operative e Concetti Teorici

Fase 1: Network Configuration e Web Server Fingerprinting

Prima di procedere all'attacco, è stata stabilita la connettività tra la macchina attaccante (Kali Linux) e il target (Metasploitable).

- **Analisi:** Attraverso il comando `cat /etc/hostname` eseguito post-exploit, abbiamo completato il **Web Server Fingerprinting**.
- **Significato:** Questa fase permette di identificare con precisione il sistema operativo e il software della vittima. Scoprire che il server risponde come **"metasploitable"** permette all'attaccante di conoscere le debolezze specifiche di quella versione di Linux

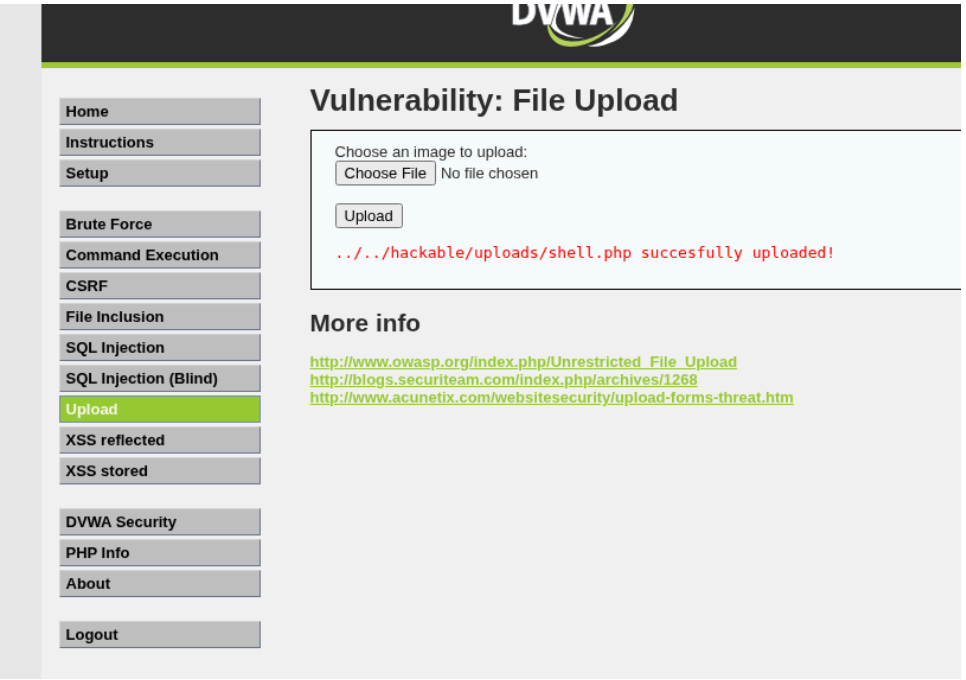



```
metasploitable
```

Fase 2: Sviluppo dell'Exploit

È stato creato uno script PHP malevolo per agire come porta d'accesso al server.

- **Analisi:** Il codice `<?php system($_REQUEST['cmd']); ?>` trasforma una variabile URL in un comando di sistema.
- **Significato Teorico:** Questo file rappresenta l'**Exploit**. Sfrutta l'assenza di filtri lato server per ottenere una **Remote Code Execution (RCE)**. È il mezzo con cui l'attaccante converte una vulnerabilità applicativa in un controllo totale del sistema operativo.



Fase 3: Intercettazione e Analisi MITM (Burp Suite)

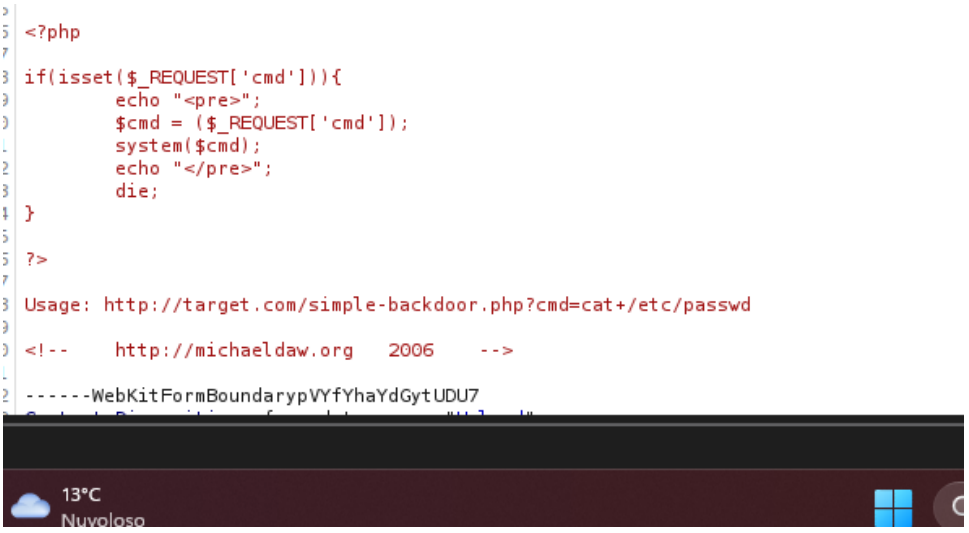
Durante il caricamento del file, è stato utilizzato Burp Suite per monitorare il traffico.

- **Analisi:** Burp Suite è stato configurato come Proxy locale tra il browser e il server target.
    - Questa operazione simula un attacco **Man-In-The-Middle (MITM)**. Intercettando la richiesta, abbiamo potuto analizzare i pacchetti HTTP in transito. Abbiamo osservato che il traffico non era cifrato, permettendoci di vedere (e potenzialmente modificare) il contenuto dell'exploit prima che raggiungesse il server.

Fase 4: Manipolazione dei Verbi HTTP

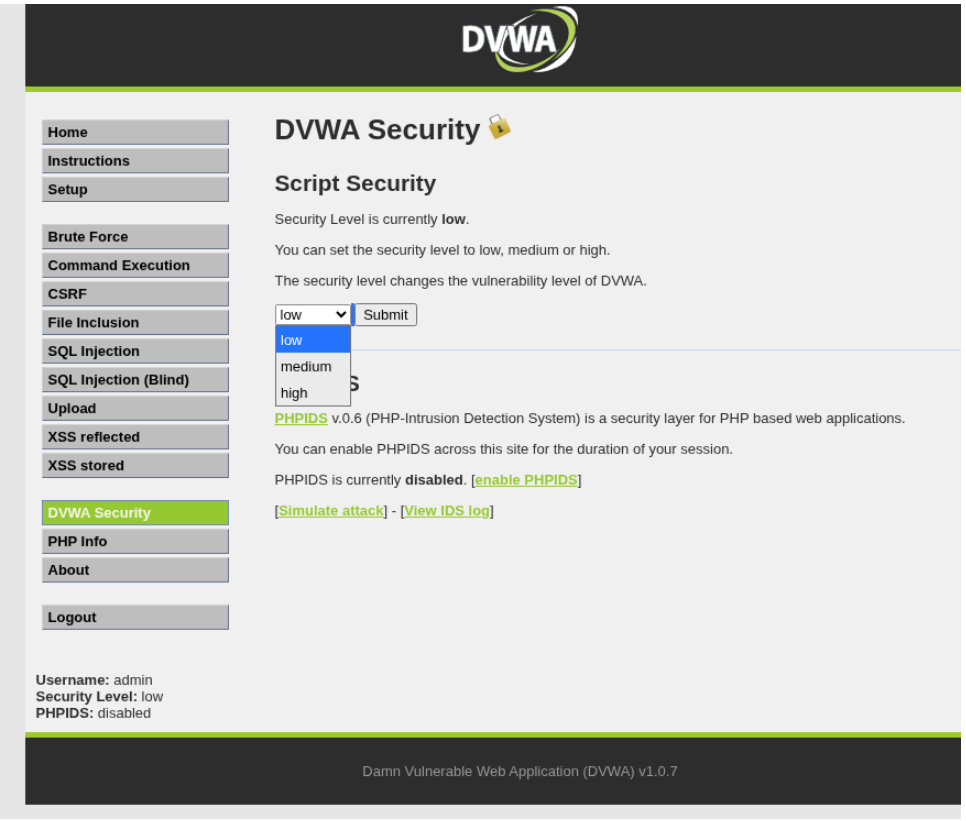
Il caricamento della shell è avvenuto tramite le funzioni web di DVWA.

- **Analisi Tecnica:** Abbiamo sfruttato il metodo **HTTP POST** per inviare il file al server. Successivamente, abbiamo usato il metodo **HTTP GET** tramite parametri URL per eseguire i comandi.
- **Significato Teorico:** L'**Exploit dei verbi HTTP** risiede nel fatto che il server accetta dati tramite POST senza validarne il contenuto (MIME-type o estensione). L'attaccante abusa della funzione legittima di "Upload" per iniettare codice, violando l'integrità del Web Server.

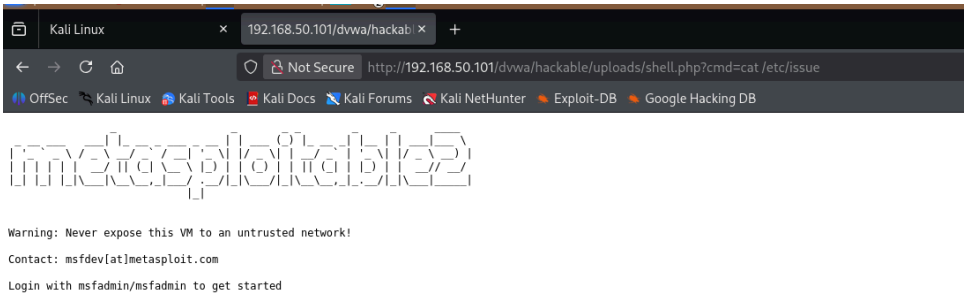


3. Risultati Ottenuti (Evidence)

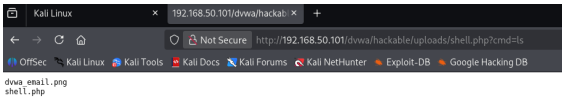
1. **Intercettazione:** Tramite Burp Suite, è stata catturata la richiesta POST contenente il payload PHP, confermando la visibilità del traffico (MITM).
2. **Compromissione:** Il file è stato caricato con successo grazie alla configurazione di sicurezza "Low".

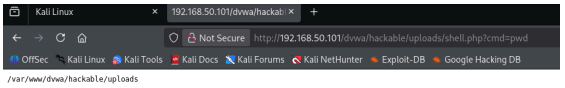


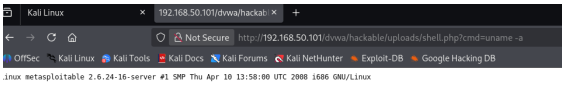
1. **Esecuzione Remota:** Tramite l'URL `shell.php?cmd=[comando]`, è stato possibile interrogare il server. La risposta **"metasploitable"** e la lettura del file `/etc/issue` rappresentano la prova inconfutabile del successo dell'attacco e del fingerprinting accurato.

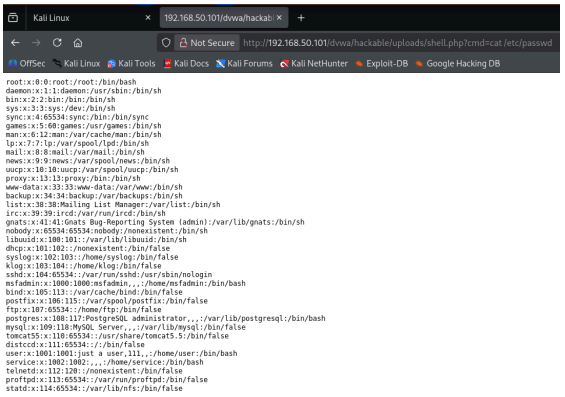


4. Post-Sfruttamento e Analisi dei risultati









5. Conclusioni e Mitigazione

L'esercitazione dimostra che la mancanza di controlli sull'input dell'utente permette attacchi devastanti. Per prevenire tali vulnerabilità, i web server dovrebbero:

- Rinominare i file caricati.

- Controllare le estensioni dei file (Whitelist).
- Limitare i permessi di esecuzione nelle cartelle di upload.